

Cada usuário de rede e dispositivo host deve ser identificado com uma conta para que você possa controlar seu acesso aos aplicativos, dados e serviços da sua organização. Os processos que suportam esse requisito são chamados de gerenciamento de identidade e acesso. Nele, as tecnologias de autenticação garantem que apenas sujeitos válidos (usuários ou dispositivos) possam operar uma conta. A autenticação exige que o titular da conta envie credenciais que só devem ser conhecidas ou mantidas por ele para acessar a conta. Existem muitas tecnologias de autenticação e é essencial que você consiga implementar e manter estes controles de segurança.

Além de garantir que apenas usuários e dispositivos válidos se conectem a redes e dispositivos gerenciados, você deve garantir que esses sujeitos recebam autorização apenas às permissões e privilégios de acesso e alteração de recursos necessários. Estas tarefas são complicadas pela necessidade de gerenciar identidades em redes locais, serviços em nuvem e aplicativos web/móveis.

Nesta lição, você fará o seguinte:

- Implementar a autenticação multifator e baseada em senha.
- Implementar políticas de contas e soluções de autorização.
- Implementar soluções de autenticação única (Single Sign-On) e identidade federada.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Supondo que uma conta foi criada de forma segura e a identidade do titular da conta foi verificada, a autenticação verifica se apenas o titular da conta pode usar a conta e se o sistema pode ser usado apenas pelos titulares da conta. Além das senhas, as tecnologias de autenticação possibilitam o uso de fatores biométricos e tokens para aumentar a segurança das contas. Identificar os pontos fortes e fracos destes fatores ajudará você a implementar e manter os sistemas de autenticação fortes.

Objetivos abordados no exame:

- 4.6 Considerando determinado cenário, implementar e manter o gerenciamento de identidade e acesso.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A autenticação é realizada quando um solicitante ou requerente apresenta credenciais a um servidor de autenticação. O servidor compara o que foi apresentado com a cópia das credenciais armazenadas. Se corresponderem, a conta será autenticada. *Design de autenticação* refere-se à seleção de uma tecnologia que atenda aos requisitos de confidencialidade, integridade e disponibilidade:

- A **confidencialidade**, em termos de autenticação, é fundamental, porque se as credenciais da conta vazarem, os autores de ameaças podem se passar pelo titular da conta e agir no sistema com os direitos que este tiver.
- **Integridade** refere-se à confiabilidade do mecanismo de autenticação, sendo difícil para autores de ameaças contorná-lo ou enganá-lo com credenciais falsas.
- **Disponibilidade** significa que o tempo necessário para autenticar não prejudica os fluxos de trabalho e é fácil o suficiente para os usuários operarem.

Há muitas tecnologias diferentes para definir credenciais. Esses podem ser categorizados como [[fatores]]. O fator de autenticação mais tradicional é “Algo que você sabe” ou fator de conhecimento.

O fator de conhecimento típico é o *login*, composto por um nome de usuário e uma senha. O nome de usuário geralmente não é segredo (embora não deva ser publicado abertamente), mas a senha deve ser conhecida apenas pelo titular da conta. Uma frase de acesso é uma senha mais longa composta por várias palavras. Ela tem a vantagem de ser mais segura e fácil de lembrar.

Figura 1. Tela de entrada do Windows



Captura de tela usada com permissão da Microsoft.

Um [[número de identificação pessoal (PIN)]] também é algo que você sabe. Originalmente, os PINs eram associados a sequências numéricas curtas de quatro ou seis dígitos usadas com cartões bancários. Nos designs de autenticação modernos, a principal característica de um PIN é que ele seja válido para autenticação em apenas um dispositivo. Esse tipo de PIN pode usar qualquer caractere e comprimento.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O gerenciamento inadequado de credenciais continua sendo um dos vetores mais eficazes para ataques à rede. Se uma organização precisa continuar a depender de credenciais baseadas em senha, seu uso precisa ser regido por políticas e treinamento sólidos.

Uma [[política de boas práticas]] para senhas orienta os usuários sobre como escolher e manter suas senhas. De forma mais geral, uma política de gerenciamento de credenciais deve instruir os usuários sobre como manter seu método de autenticação seguro, seja uma senha, smart card (cartão inteligente) ou identificação biométrica. A política de gerenciamento de credenciais também precisa alertar os usuários quanto aos diversos tipos de ataques de social engineering (engenharia social). Os usuários precisam ser capazes de detectar as tentativas de phishing e pharming, para que não insiram credenciais em um formulário inseguro ou site falsificado.

Para complementar a conscientização sobre boas práticas, [[políticas de contas]] aplicadas pelo sistema podem ajudar a garantir os princípios de gerenciamento de credenciais ao estipular requisitos para senhas escolhidas pelos usuários:

- **Comprimento da senha:** impõe um comprimento mínimo para senhas. Pode haver também um comprimento máximo.
- **Complexidade de senha:** aplica regras de complexidade de senha (como a proibição do uso do nome de usuário na senha e a exigência de uma combinação de pelo menos oito caracteres maiúsculos/minúsculos, alfanuméricos e não alfanuméricos).
- **Idade da senha:** força o usuário a selecionar uma nova senha após um número definido de dias.
- **Reutilização de senha e histórico:** impede a seleção de uma senha que já foi usada. O atributo de histórico define quantas senhas anteriores estão bloqueadas. O atributo de idade mínima impede que um usuário altere rapidamente as senhas para voltar a uma frase preferida.

Nota:

O envelhecimento e o vencimento da senha podem significar a mesma coisa. No entanto, alguns sistemas fazem uma diferenciação entre eles. Se esse for o caso, o envelhecimento significa que o usuário ainda pode fazer login com a senha antiga após o período definido, mas deve escolher imediatamente uma nova senha. Vencimento significa que o

usuário não pode mais entrar com a senha desatualizada e a conta está efetivamente desativada.

Nota:

É importante observar que as orientações mais recentes emitidas pelo NIST descontinuam alguns dos elementos “tradicionais” das boas práticas de senha, como complexidade, expiração e uso de dicas de senha.

Nota:

A reutilização de senha também pode significar o uso de uma senha de trabalho em qualquer outro lugar (em um site de compras, por exemplo). Esse tipo de comportamento só pode ser controlado por políticas “suaves”.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os usuários geralmente adotam práticas ruins de gerenciamento de credenciais que são difíceis de controlar, como usar a mesma senha para redes corporativas e sites de consumidores. Isso torna a segurança da rede corporativa vulnerável a violações de dados provenientes desses sites. Esse risco é mitigado por um [[gerenciador de senhas]]:

1. O usuário seleciona um aplicativo ou serviço gerenciador de senhas.

A maioria dos sistemas operacionais e navegadores implementa gerenciadores de senhas. Alguns exemplos são o Gerenciador de Credenciais do Windows e o iCloud Keychain da Apple. Se estiver usando um gerenciador de senhas externo, o usuário instala um plug-in no navegador escolhido.

2. O usuário protege o cofre de senhas com uma senha mestra.

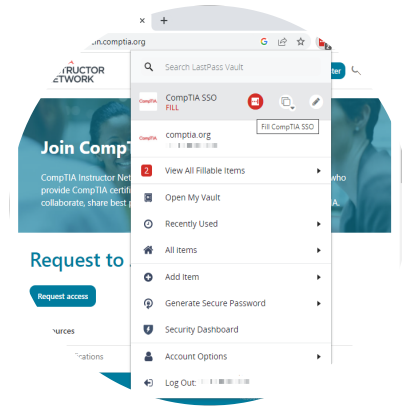
É provável que o cofre seja armazenado na nuvem para que as contas sejam acessadas em vários dispositivos, mas alguns gerenciadores de senhas oferecem apenas armazenamento local.

3. Quando o usuário cria ou atualiza uma conta, o gerenciador de senhas gera uma senha aleatória.

Os parâmetros podem ser ajustados para atender a qualquer política de comprimento e complexidade exigida pelo site.

4. Quando o usuário navega posteriormente em um site, o gerenciador de senhas valida a identidade do site usando seu certificado digital e apresenta uma opção para o usuário preencher a senha.

Figura 1. Uso do plug-in do navegador do gerenciador de senhas LastPass para entrar no site da CompTIA



Captura de tela cortesia da CompTIA, Inc. e da LastPass US LP.

Os principais riscos dos gerenciadores de senhas são a seleção de uma senha mestra fraca, o comprometimento do armazenamento ou dos sistemas em nuvem do fornecedor e os ataques de personificação criados para enganar o gerenciador e levá-lo a preencher uma senha em um site falso.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um design de autenticação que usa apenas senhas ou um único fator de conhecimento é considerado fraco. Segredos de senhas são muito propensos a comprometimento para serem confiáveis. Outros tipos de fator de autenticação podem ser usados para complementar ou substituir logins baseados em senha. Uma [[tecnologia de autenticação multifator (MFA)]] combina o uso de mais de um tipo de fator.

Fator “algo que você tem”

Algo que você possui é um *fator de posse*. Isso significa que o titular da conta possui algo que ninguém mais possui, como um smart card (cartão inteligente), chaveiro eletrônico ou smartphone que pode gerar ou receber um token criptográfico.

Fator “algo que você é”

“Algo que você é” refere-se a um fator biométrico ou inerente. Um *fator biométrico* usa identificadores fisiológicos, como impressão digital ou digitalização facial, ou identificadores comportamentais, como a forma de alguém se mover (andadura). Os identificadores são escaneados e registrados como um modelo. Ao fazer a autenticação, o usuário é escaneado novamente e comparado ao modelo.

Fator “algum lugar em que você está”

“Algum lugar em que você está” significa que o sistema aplica um fator baseado em localização a uma decisão de autenticação. A autenticação baseada em localização mede algumas estatísticas sobre onde você está. Pode ser uma localização geográfica medida usando o serviço de localização de um dispositivo ou seu endereço de rede de Protocolo de Internet (IP). O endereço IP de um dispositivo pode ser usado para indicar um segmento de rede lógica ou pode ser vinculado a uma localização geográfica usando um serviço de geolocalização. Dentro de uma rede de instalações, a localização da porta física, a LAN virtual (VLAN) ou a rede Wi-Fi também podem ser o fundamento da autenticação baseada em localização.

A autenticação baseada em localização não é usada como um fator de autenticação principal, mas pode ser usada como um mecanismo de autenticação contínuo ou como um recurso de controle de acesso. Por exemplo, se um usuário inserir as credenciais corretas em um gateway de acesso remoto, mas seu endereço IP mostrar que ele está em um país diferente do esperado, os controles de acesso poderão ser aplicados para restringir os privilégios concedidos ou recusar completamente o acesso. Outro exemplo é quando um usuário parece fazer login a partir de várias localizações geográficas que seriam fisicamente impossíveis em virtude do tempo de viagem necessário.

Nota:

A autenticação multifator requer uma combinação de diferentes tecnologias. Por exemplo, exigir um PIN juntamente com a data de nascimento pode ser mais forte do que apenas inserir um PIN, mas não é multifator.

Nota:

Você também pode ver referências à autenticação de dois fatores (2FA). Isso significa apenas que há precisamente dois fatores envolvidos, como um smart card de posse individual ou identificador biométrico com algo que você conhece, como uma senha ou PIN.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O primeiro passo para configurar a [[autenticação biométrica]] é o cadastro:

1. Um módulo sensor coleta a amostra biométrica do alvo.
2. Um módulo de extração de características cria um modelo,

ou seja, uma representação matemática das partes da amostra que identificam exclusivamente o sujeito.

Quando o usuário quer acessar um recurso, ele passa por uma nova verificação, que é então comparada com o modelo. Se forem correspondentes em um grau de tolerância definido, o acesso será concedido.

A autenticação biométrica pode ser desafiadora de implementar. A taxa de eficácia da aquisição e correspondência de padrões biométricos e a adequação como mecanismo de autenticação podem ser avaliadas usando as seguintes métricas e fatores:

- [[Taxa de rejeição falsa (FRR)]]: ocorre quando um usuário legítimo não é reconhecido. Isso também é chamado de erro Tipo I ou taxa de não correspondência falsa (FNMR). A FRR é medida em porcentagem.
- [[Taxa de rejeição falsa (FRR) 2]]: ocorre quando um usuário legítimo não é reconhecido. A FAR é medida em porcentagem.

A rejeição falsa causa inconvenientes aos usuários, mas a aceitação falsa pode levar a violações de segurança e, por isso, é geralmente considerada a métrica mais importante.

- [[Taxa de erro cruzado (CER)]]: é o ponto em que a FRR e a FAR se igualam. Quanto mais baixa é a CER, mais eficiente e confiável é a tecnologia.

Os erros diminuem ao longo do tempo com ajustes no sistema. Para isso, geralmente se ajusta a sensibilidade do sistema até atingir a CER.

- **Taxa de transferência (velocidade):** é o tempo necessário para criar um modelo para cada usuário e o tempo necessário para se autenticar. Essa é uma consideração importante para access points com tráfego intenso, como aeroportos ou estações ferroviárias.
- **Taxa de falha no registro (FER):** são incidentes nos quais não é possível criar e relacionar um modelo a um usuário durante o registro.
- **Custo/implementação:** alguns tipos de leitor são mais caros, enquanto outros não são fáceis de incorporar em dispositivos móveis.
- Os usuários podem achá-lo intrusivo e uma ameaça à privacidade.
- A tecnologia pode ser discriminatória ou inacessível para pessoas com deficiência.

O reconhecimento de impressões digitais é o método de autenticação biométrica mais amplamente implementado. A tecnologia necessária para digitalizar e registrar impressões digitais é relativamente barata e o processo é bastante simples. Um sensor de impressão digital é geralmente implementado como uma pequena célula capacitiva ou câmera

óptica que pode detectar o padrão único de cristas que compõem a impressão digital. Além disso, a tecnologia não é intrusiva e é relativamente simples de usar, embora a umidade ou sujeira possam impedir as leituras.

Figura 1. Configurando o reconhecimento de impressão digital em um smartphone Android™. Android é uma marca registrada do Google LLC.



O título no topo diz: Ótimo! Agora, repita. O texto abaixo do cabeçalho diz: mova levemente seu dedo para adicionar todas as diferentes partes da sua impressão digital. Abaixo do texto, há um sensor de impressão digital para registrar a impressão.

O reconhecimento facial registra vários indicadores relacionados ao tamanho e formato do rosto, como a distância entre os olhos ou a largura e o comprimento do nariz. A digitalização geralmente usa câmeras ou sensores ópticos e infravermelhos para evitar tentativas de falsificação que usam uma foto em vez de um rosto real.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Fator de propriedade significa que o usuário possui algum tipo de dispositivo que só ele pode operar. Isso é denominado autenticador. O autenticador é capaz de gerar ou receber um token que identifica e autentica o usuário. Existem três tipos principais de geração de token:

- **Autenticação baseada em certificado:** é quando o requerente controla uma chave privada que pode gerar um token assinado exclusivo. O provedor de identidade pode verificar a assinatura por meio da chave pública. A principal desvantagem dessa abordagem é a carga administrativa da implementação da PKI para emissão de certificados digitais.
- **Senha de uso único (OTP):** é quando um token é gerado usando algum tipo de função hash em um valor de segredo compartilhado, além de uma semente de sincronização, como uma marca de data/hora (TOTP) ou um

HMAC (HOTP). O token só pode ser usado uma vez. Um novo token é gerado para cada decisão de autenticação. Essa abordagem ainda usa um par de chaves e hash para segurança, mas não requer uma PKI.

- **Fast Identity Online (FIDO) Universal 2nd Factor (U2F)**: usa um par de chaves pública/privada para registrar cada conta, evitando a necessidade de comunicar um segredo compartilhado, que é um ponto fraco do HOTP e do TOTP. A chave privada fica protegida no dispositivo U2F e assina o token. A chave pública é registrada no servidor de autenticação e verifica o token. Embora não haja certificados digitais envolvidos na autenticação de usuários, a PKI é utilizada na validação/confirmação de certificados de atestação.

Um [[token de autenticação física]] é gerado dentro de um criptoprocessador seguro. O design de autenticação sugere que não há transmissão do token em si. Vários autenticadores em dispositivos podem ser usados para implementar tokens físicos:

- [[Smart cards]]: implementam autenticação baseada em certificado. O cartão inteligente armazena o certificado digital do usuário, a chave privada associada ao certificado e um número de identificação pessoal (PIN) usado para ativar o cartão. O cartão deve ser apresentado a um leitor. Existem cartões de contato físico e por aproximação que usam tecnologia de comunicação a curta distância (NFC).
- [[Senha de uso único (OTP)]]: refere-se a um criptoprocessador capaz de gerar um token. Esse tipo de token de hardware não precisa de uma interface para se conectar a um computador; o usuário apenas lê o código exibido.
- [[Chave de segurança]]: refere-se a um módulo de segurança de hardware (HSM) portátil com interface para computador, como USB ou NFC. Esses autenticadores estão mais associados ao U2F, mas alguns também podem suportar a autenticação baseada em certificado ou HOTP/TOTP. Uma chave de segurança deve ser ativada para mostrar presença. Algumas chaves possuem apenas um botão de ativação, mas a maioria usa um leitor biométrico de impressões digitais para maior segurança. Também é necessário configurar um PIN como mecanismo de backup.

Figura 1. Gerador de token de key fob.



Imagem © 123RF.com.

Nota:

Existem também cartões inteligentes e geradores de token físicos mais simples, que apenas transmitem um token estático programado no dispositivo. Por exemplo, muitos sistemas de entrada em edifícios funcionam com base em códigos estáticos. Esses mecanismos são altamente vulneráveis a ataques de repetição (replay attack) e clonagem.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um [[token de autenticação lógico]] é uma senha de uso único gerada pelo provedor de identidade e transmitida ao solicitante. A OTP pode ser enviada via SMS/mensagem de texto para um número de telefone registrado ou para uma conta de e-mail. É mais provável que esse método use tokens baseados em contador, embora ainda tenham um período de validade.

Nota:

“Soft tokens” (tokens de software) enviados por SMS ou e-mail não são considerados de fato como um fator de propriedade. Esses sistemas podem ser descritos como verificação em duas etapas, em vez de MFA. Os tokens são altamente vulneráveis à interceptação.

Um token OTP lógico mais seguro pode ser gerado utilizando um aplicativo autenticador. Esse é um software instalado em um computador ou smartphone. O usuário deve registrar cada provedor de identidade no aplicativo, normalmente usando um código QR (quick response, ou resposta rápida) digitalizável para comunicar o segredo compartilhado.

Quando a autenticação for solicitada, o usuário deve desbloquear o aplicativo autenticador com a credencial do dispositivo para visualizar o token OTP. O risco de interceptação é menor do que com mensagens via SMS ou e-mail. Contudo, por funcionar em um dispositivo de uso compartilhado, existe a possibilidade de um malware comprometer o aplicativo.

Figura 1. Uso de um aplicativo autenticador para fazer login em um site. Depois que o usuário entra com uma senha, o site solicita que ele autorize o login usando o aplicativo autenticador instalado em seu smartphone.



Descrição

O laptop está com o navegador aberto no site <https://www.comptia.org> (<https://www.comptia.org>). A página do site possui uma caixa de verificação com as palavras “Verifique sua identidade”; abaixo está a orientação: “Verifique seu telefone para uma notificação push”. Um número de telefone com asteriscos e um ícone de notificação push aparecem abaixo das instruções. No final da caixa de verificação, estão sublinhados “Outras opções” e “Precisa de ajuda?”. O smartphone exibe um símbolo de configurações com a pergunta “Você está entrando com Office 365?”. Há também um ícone de localização com um endereço, um ícone de relógio com o horário e um ícone de pessoa com um endereço de e-mail em uma lista. Abaixo da lista, há um “x” em um círculo com o rótulo “Negar” e uma marca de verificação em um círculo com o rótulo “Aprovar”.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Com a MFA baseada em token, a conta do usuário geralmente ainda é configurada com uma senha. Ela pode ser usada como um mecanismo de backup ou pode haver um processo de verificação em duas etapas, no qual o usuário deve informar a senha e, em seguida, enviar uma OTP.

[[Passwordless]] significa que todo o sistema de autenticação deixa de processar fatores baseados em conhecimento. O FIDO2 com especificações WebAuthn fornece uma estrutura para autenticação sem senha. Funciona basicamente da seguinte maneira:

1. O usuário escolhe um autenticador externo, como uma chave de segurança, ou um autenticador de plataforma implementado pelo sistema operacional do dispositivo, como o Windows Hello ou o Face ID/Touch ID dos sistemas macOS e iOS.
2. O usuário configura um método seguro ou gesto local para confirmar a presença e autentica o dispositivo.

Esse gesto pode ser uma impressão digital, reconhecimento facial ou PIN. Essa credencial só é validada localmente pelo autenticador.

3. O usuário se registra em um aplicativo ou serviço web que chamamos de “parte confiável”.

Para cada nova parte confiável, o autenticador gera um par de chaves pública/privada. O navegador cliente do usuário obtém a chave pública do autenticador e a registra para associá-la a uma conta na parte confiável.

4. Ao se deparar com um desafio de autenticação, o usuário executa o gesto local para desbloquear a chave privada.

A chave privada é usada para assinar uma confirmação de que o gesto local funcionou, que é então enviada à parte confiável.

5. A parte confiável usa a chave pública para verificar a assinatura e autenticar a sessão da conta.

Assim como o FIDO U2F, isso proporciona uma segurança semelhante à autenticação por cartão inteligente, mas não exige que as contas tenham certificados digitais e PKI, o que reduz a carga de gerenciamento. O FIDO2 com WebAuthn aprimora o FIDO U2F ao adicionar uma interface de programação de aplicativo (API) que permite que os aplicativos web funcionem sem um elemento de senha para autenticação. A maioria dos autenticadores FIDO U2F também é compatível com o FIDO2/WebAuthn.

Para que um sistema sem senha seja seguro, o autenticador deve ser confiável e resistente a ataques de falsificação ou clonagem. [[Atestação]] é um mecanismo pelo qual um dispositivo autenticador, como uma chave de segurança FIDO ou o TPM de um PC ou laptop, comprova que é uma raiz de confiança. Cada chave de segurança é fabricada com uma atestação e um ID de modelo. Durante a etapa de registro, se a parte confiável exigir atestação, o autenticador usará essa chave para enviar um relatório. A parte confiável pode conferir o relatório de atestado para verificar se o autenticador é de uma marca e modelo conhecidos e se é compatível com as propriedades criptográficas exigidas pela parte confiável.

Nota:

Observe que a chave de atestação não é exclusiva. Se fosse, seria fácil identificar indivíduos, o que representaria uma séria ameaça à privacidade. Em vez disso, ela identifica uma determinada marca e modelo.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Uma conta de usuário que foi autenticada pode receber direitos e [[permissões]] em redes, computadores e dados.

Modelos de controle de acesso descrevem os princípios que determinam como os usuários recebem direitos.

Controle de acesso discricionário

O [[controle de acesso discricionário (DAC)]] é baseado na primazia do proprietário do recurso. Em um modelo DAC, cada recurso tem um proprietário. O proprietário cria um arquivo ou serviço, mas a posse pode ser atribuída a outro usuário. O proprietário tem controle total sobre o recurso e pode modificar sua lista de controle de acesso (ACL) para conceder direitos a terceiros.

O DAC é o modelo mais flexível e é amplamente implementado na segurança de computadores e redes. Para a segurança do sistema de arquivos, este é o modelo usado por padrão na maioria das distribuições UNIX/Linux e no Microsoft Windows. Por ser o modelo mais flexível, é também o mais fraco, pois dificulta a administração centralizada das políticas de segurança. Também é o mais fácil de se infringir, pois é vulnerável a ameaças internas e ao uso indevido de contas comprometidas.

Controle de acesso obrigatório

O modelo DAC expõe informações à ameaça de comprometimento através das contas de proprietários privilegiados. O [[controle de acesso obrigatório (MAC)]] é baseado em níveis de autorização de segurança. Em vez de definir ACLs nos recursos, cada objeto recebe um rótulo de classificação e cada indivíduo recebe um nível de autorização. Em um sistema multinível com foco na confidencialidade, os indivíduos têm permissão para ler objetos classificados em seu próprio nível de autorização ou em níveis inferiores. Por exemplo, um usuário com o nível de autorização “Ultrassegredo” poderá ler dados dos níveis Ultrassegredo, Secreto e Confidencial. Um usuário com a autorização “Secreto” poderá acessar apenas dados nos níveis Secreto e Confidencial.

A classificação de objetos e a concessão de autorização são realizadas usando regras pré-estabelecidas. O ponto crítico é que essas regras não são discricionárias e não podem ser alteradas por nenhuma conta de usuário.

Nota:

Como sistemas de classificação simples são inflexíveis, a maioria dos modelos MAC inclui o conceito de acesso baseado em compartimentos. Por exemplo, um arquivo de dados pode ser classificado como “Secreto” e estar localizado no compartimento de RH. Somente indivíduos com autorização de acesso aos dados no nível “Secreto” e de RH podem acessar o arquivo.

Nota:

No MAC, usuários com níveis elevados de autorização não têm permissão de gravação em documentos de baixa autorização. Isso é chamado de write up, read down (gravação em níveis altos, leitura em níveis baixos). Isso evita, por exemplo, que um usuário com o nível de autorização Ultrassegredo republique dados ultrassegredos que possam ser acessados pelo nível de autorização Secreto.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Controles de acesso baseados em função e em atributos usam atribuições de permissões não discricionárias e baseadas em regras com mais flexibilidade do que o MAC.

Controle de acesso baseado em função

O [[controle de acesso baseado em função (RBAC)]] significa que uma organização define seus requisitos de permissão com base nas tarefas que um colaborador ou serviço deve ser capaz de executar. Cada conjunto de permissões é uma função. Cada entidade principal (usuário ou conta de serviço) é alocada em uma ou mais funções. Nesse sistema, o direito de modificar as permissões atribuídas a cada função é reservado a um proprietário do sistema. Portanto, o sistema é não discricionário, pois nenhuma entidade principal pode modificar a ACL de um recurso, mesmo que possa alterar o recurso de outras maneiras. As entidades principais obtêm direitos de forma implícita (ao receber uma função), e não explícita (com o direito atribuído diretamente). As ACLs de sistema de arquivos, seja em armazenamento local ou em rede, são onde essas permissões são armazenadas e aplicadas.

O conceito de conta de security [[group contribui]] para transformar um sistema discricionário em um sistema baseado em funções. Em vez de atribuir direitos diretamente a contas de usuários, o proprietário do sistema atribui contas de usuários a contas de grupos de segurança. As entidades principais obtêm direitos ao serem incluídas num grupo de segurança. Uma entidade principal pode ser membro de diversos grupos e, com isso, receber direitos e permissões de várias fontes. Essa abordagem pode ser aplicada em diferentes sistemas operacionais, incluindo ambientes Windows e Unix/Linux, para garantir um sistema de gerenciamento de permissões flexível e escalável.

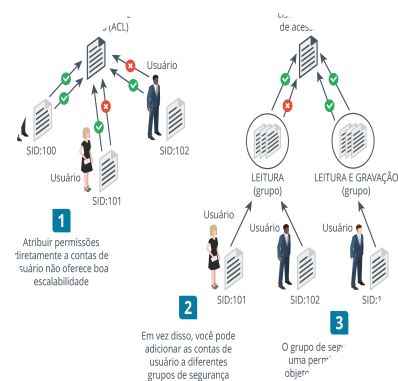


Figura 1. Uso de grupos de segurança para atribuir privilégios.

Imagens © 123RF.com.

Descrição

As etapas são as seguintes: 1. Atribuir permissões diretamente às contas de usuário não é uma solução escalável. 2. Em vez disso, as contas de usuário podem ser associadas a diferentes security groups. 3. O security group recebe permissão na ACL do objeto e a conta de usuário herda as permissões do grupo. Isso garante que as permissões sejam aplicadas de forma consistente no nível do sistema de arquivos, independentemente do sistema operacional subjacente.

O RBAC pode ser parcialmente implementado associando grupos de segurança a funções, mas eles não são esquemas idênticos. A participação em grupos de segurança é em grande parte discricionária (atribuída pelos administradores em vez de determinada pelo sistema). Além disso, o ideal é que uma entidade principal herde as permissões de uma função

somente para concluir uma tarefa específica, e não as mantenha de forma permanente. Os administradores devem ser impedidos de aumentar seus próprios privilégios, seja atribuindo arbitrariamente funções às suas contas ou aumentando as permissões de uma função.

Controle de acesso baseado em atributos

O [[controle de acesso baseado em atributos (ABAC)]] é o modelo de controle de acesso mais granular. Como o nome sugere, um sistema ABAC toma decisões de acesso com base em uma combinação de atributos de indivíduo e objeto, além de quaisquer atributos de sistema ou sensíveis ao contexto. Além da associação a grupos/função, esses atributos podem incluir informações sobre o sistema operacional que está sendo usado no momento, o endereço IP ou a presença de patches atualizados e antimalware. Por exemplo, um sistema baseado em atributos pode considerar as diferentes limitações de autenticação e de pertencimento a grupos encontradas em soluções de armazenamento em rede, como NFS em ambientes Unix/Linux. Sistemas baseados em atributos monitoram o número de eventos ou alertas associados a uma conta de usuário ou a um recurso, ou rastreiam solicitações de acesso para verificar se são coerentes em termos de tempo ou localização geográfica. Eles podem ser programados para implementar políticas como controle “M de N” e separação de funções. O controle M de N é uma medida de segurança que exige que um número mínimo (M) de agentes, de um total (N), trabalhe em conjunto para executar uma tarefa de alto nível de segurança, como a assinatura de chaves.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O [[controle de acesso baseado em regras]] refere-se a qualquer tipo de modelo de controle de acesso em que as políticas são determinadas por regras aplicadas pelo sistema, em vez de pelos usuários. Dessa forma, RBAC, ABAC e MAC são exemplos de controle de acesso baseado em regras (ou não discricionário).

O acesso condicional é um exemplo de controle de acesso baseado em regras. Sistemas de acesso condicional monitoram o comportamento da conta ou do dispositivo durante uma sessão. Se determinadas condições forem atendidas, o sistema poderá suspender a conta ou exigir que o usuário faça uma nova autenticação, talvez usando um método de verificação em duas etapas.

O controle de conta do usuário (UAC) e as restrições sudo em contas privilegiadas são exemplos de acesso condicional. Quando o usuário faz solicitações que requerem privilégios elevados, é solicitada uma confirmação ou autenticação. O gerenciamento de direitos baseado em função e os sistemas ABAC podem aplicar vários critérios ao acesso condicional, incluindo políticas da localização.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

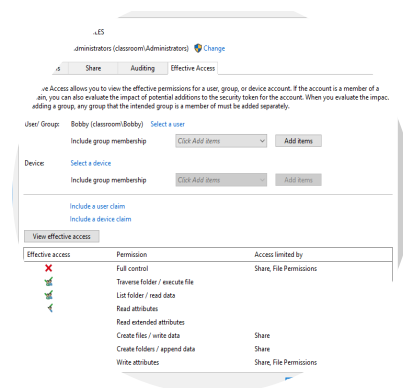
[[Privilégio mínimo]] significa que a uma entidade são concedidos apenas os direitos mínimos necessários para realizar uma tarefa para a qual está autorizada. Isso mitiga os riscos caso uma conta seja comprometida e fique sob controle de um autores de ameaças. O privilégio mínimo envolve uma fase de design, em que uma análise de fluxos de trabalho empresariais determina quais funções e permissões são necessárias.

Embora o privilégio mínimo seja um forte princípio de design, implementá-lo com sucesso pode ser um desafio. Quando muitos usuários, grupos, funções e recursos estão envolvidos, gerenciar atribuições de permissão e implicações é um processo complexo e demorado. Contas configuradas incorretamente podem ter dois impactos. Por um lado, definir privilégios muito restritivos gera um grande volume de chamadas de suporte e reduz a produtividade. Por outro lado, conceder privilégios de mais aos usuários enfraquece a segurança do sistema e aumenta o risco de infecção por malware e violação de dados.

Garantir o privilégio mínimo também envolve monitoramento contínuo para evitar o aumento de permissões. Isso acontece quando um usuário adquire cada vez mais direitos, seja diretamente ou ao ser adicionado a grupos de segurança ou funções.

Por exemplo, um usuário pode receber privilégios elevados temporariamente. Nesse caso, é necessário um sistema para garantir que os privilégios sejam revogados no final do período acordado. Um sistema de auditoria deve revisar regularmente os privilégios, monitorar a associação a grupos, revisar as listas de controle de acesso de cada recurso e identificar e desativar contas desnecessárias.

Figura 1. Definição de permissões efetivas de uma pasta compartilhada



Captura de tela usada com permissão da Microsoft.

Descrição

As abas abaixo do nome e dos detalhes do proprietário são: permissões, compartilhamento, auditoria e acesso efetivo (selecionada). Uma linha de texto é seguida por várias opções sob os títulos usuário/grupo e dispositivo. Os links abaixo exibem: incluir uma reivindicação de usuário e incluir uma reivindicação de dispositivo. Um botão abaixo dos links exibe: visualizar acesso efetivo. O botão é seguido por uma tabela que lista os dados sob os títulos: acesso efetivo, permissão e acesso limitado por. Os três botões no canto inferior direito mostram: OK, Cancelar e Aplicar. OK está selecionado e Aplicar está inativo.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Provisionamento]] é o processo de configuração de um serviço de acordo com um procedimento padrão ou uma lista de verificação de boas práticas. O departamento de TI deve monitorar todos os ativos sob gerenciamento, e as contas de usuário são um tipo de ativo. Contas de usuário são fornecidas para novos funcionários e para acesso temporário, como consultores e terceirizados. Algumas empresas também podem precisar configurar contas de cliente.

Provisionar uma conta de usuário envolve as seguintes etapas gerais:

- **Prova de identidade:** verifica se a pessoa é quem diz ser por meio de documentos e registros oficiais. As circunstâncias também podem exigir uma verificação de antecedentes, que confere endereços atuais e anteriores, formação ou emprego anterior e se a pessoa tem antecedentes criminais ou problemas relacionados a crédito.
- **Emissão de credenciais:** permite que o usuário selecione uma senha conhecida apenas por ele e/ou se registre com autenticadores biométricos ou por token.
- **Emissão de ativos de hardware e software:** o usuário precisará, normalmente, de um computador e/ou smartphone e, possivelmente, de cópias locais de aplicativos de software licenciados. Os funcionários precisam de recursos suficientes para realizar seu trabalho. Se os recursos fornecidos forem inadequados ou insuficientes, eles podem tentar obter hardware e software diretamente (shadow IT, ou TI invisível).
- **Conscientização sobre as políticas:** oferecendo treinamento e acesso a recursos de aprendizagem para que o funcionário ou terceirizado esteja ciente das políticas e riscos de segurança. Também devem estar cientes das políticas de uso pessoal dos ativos de TI concedidos a eles.
- **Criação de atribuição de permissões:** identificando as funções de trabalho que a conta deve suportar e configurando os direitos apropriados usando um modelo de controle de acesso baseado em função, obrigatório ou baseado em atributos. Se a conta tiver acesso privilegiado, ela deverá ser rotulada para um monitoramento mais rigoroso.

O [[desprovisionamento]] é o processo de remoção dos direitos de acesso e permissões atribuídos a um colaborador quando ele deixa a empresa ou a um contratado quando um projeto é finalizado. Isso envolve remover a conta de quaisquer funções ou grupos de segurança. A conta pode ser desativada por um período e posteriormente excluída ou pode ser excluída imediatamente.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

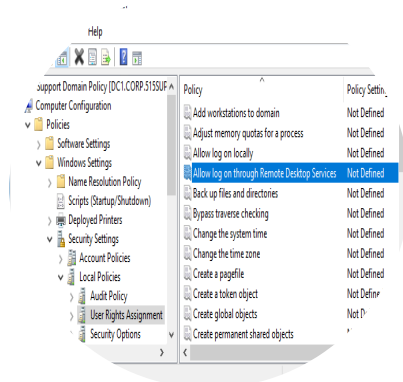
Uma conta de usuário é definida por um [[identificador de segurança (SID)]] exclusivo, um nome e uma credencial. Cada conta está associada a um perfil. O perfil pode ser definido com atributos de identidade personalizados que descrevem o usuário, como nome completo, endereço de e-mail, número de contato, departamento etc. Também pode incluir mídias, como uma foto do perfil.

Além dos atributos, o perfil geralmente fornece um local para armazenar arquivos de dados gerados pelo usuário (uma pasta inicial). O perfil também pode armazenar configurações específicas da conta para aplicativos de software.

Cada conta pode receber permissões sobre arquivos e outros recursos de rede e políticas de acesso ou privilégios sobre o uso e a configuração de hosts de rede. Essas permissões podem ser atribuídas diretamente à conta ou herdadas através da associação a um grupo de segurança ou função. As políticas de acesso determinam questões como o direito de iniciar sessão em um computador localmente ou por uma área de trabalho remota, de instalar software, de alterar a configuração da rede etc.

Em uma rede Windows Active Directory, as políticas de acesso podem ser configuradas por meio de [[objetos de diretiva de grupo (GPOs)]]. Os GPOs podem ser usados para configurar direitos de acesso para contas de usuário/grupo/função. Os GPOs podem ser vinculados a limites administrativos de rede no Active Directory, como sites, domínios e unidades organizacionais (UO).

Figura 1. Configuração de políticas e direitos de acesso usando objetos de política de grupo no Windows Server 2016.



Captura de tela usada com permissão da Microsoft.

Descrição

O menu no topo exibe: arquivo, ação, exibir e ajuda. Abaixo, um painel à esquerda mostra opções para “515 support domain policy”, com “atribuição de direitos do usuário” selecionado. À direita, várias políticas e configurações de políticas estão listadas. A política “Permitir logon por meio de serviços de área de trabalho remota” com a configuração de política “não definido” está selecionada.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Restrições baseadas em políticas podem ser usadas para mitigar riscos de comprometimento da conta por roubo de credenciais.

Políticas baseadas em localização

Um usuário ou dispositivo pode ter uma localização de rede lógica, identificada por um endereço IP, sub-rede, LAN virtual (VLAN) ou unidade organizacional (UO). Isso pode ser usado como um mecanismo de restrição de conta. Por exemplo, uma conta de usuário pode ser impedida de fazer login localmente em servidores dentro de uma unidade organizacional restrita.

A localização [[geográfica]] de um usuário ou dispositivo pode ser calculada por meio de um mecanismo de geolocalização:

- O **endereço de IP** pode ser associado a um local de mapa com vários graus de precisão com base nas informações publicadas pelo registrante, incluindo nome, país, região e cidade. O registrante geralmente é o provedor de serviços da Internet (ISP), portanto, as informações que você receber fornecerão uma localização aproximada de um host com base no ISP. Se o ISP atende a uma área geográfica grande ou diversificada, é mais difícil identificar a localização dos provedores de serviços da Internet (ISPs) para hosts. Bibliotecas de software, como GeoIP, facilitam a consulta desses dados.
- Os **serviços de localização** são métodos usados pelo sistema operacional para calcular a posição geográfica do dispositivo. Um dispositivo com um sensor de sistema de posicionamento global (GPS) pode relatar uma localização altamente precisa quando estiver ao ar livre. Os serviços de localização também podem triangular para torres de celular, access points Wi-Fi e sinais Bluetooth onde o GPS não é compatível.

Restrições temporais

Existem quatro tipos principais de políticas temporais:

- Uma política de [[restrição por horário]] determina os horários autorizados de login para uma conta.
- Uma **política de login com base em duração** estabelece o tempo máximo que uma conta pode permanecer conectada.
- Uma **política de tempo de viagem impossível/login arriscado** rastreia a localização dos eventos de login ao longo do tempo. Se eles não atingirem um limite, a conta será desativada. Por exemplo, um usuário fez login em uma conta de um dispositivo na cidade de Nova York. Duas horas depois, uma tentativa de login é feita a partir de Los Angeles, mas é recusada e um alerta é acionado porque não é viável que o usuário esteja em ambos os locais.
- Uma **política de permissões temporárias** remove uma conta de uma função ou grupo de segurança após um período definido.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os usuários padrão têm privilégios limitados, geralmente com acesso para executar programas e criar e modificar arquivos pertencentes apenas ao seu perfil.

Uma conta privilegiada pode fazer alterações significativas nas configurações de um host, como instalar software ou desativar um firewall ou outro sistema de segurança. As contas privilegiadas também têm o direito de gerenciar dispositivos de rede, servidores de aplicativos e bancos de dados.

O [[gerenciamento de acesso privilegiado (PAM)]] refere-se a políticas, procedimentos e controles técnicos para prevenir o comprometimento de contas privilegiadas. Esses controles identificam e documentam as contas privilegiadas, dando visibilidade ao seu uso, além de gerenciar as credenciais usadas para acessá-las.

Nota:

É uma boa ideia restringir o máximo possível o número de contas administrativas. Quanto mais contas houver, mais provável será que uma delas seja comprometida. Por outro lado, não é desejável que os administradores compartilhem contas ou usem contas padrão, pois isso compromete a prestação de contas.

Os usuários com privilégios administrativos devem ter o maior cuidado com a gestão de credenciais. As contas de acesso privilegiado devem usar senhas fortes e, de forma ideal, autenticação multifator (MFA) ou autenticação sem senha.

Nota:

Para proteger as credenciais de contas privilegiadas, administradores devem realizar seu trabalho em dispositivos designados, em vez de confiar em qualquer dispositivo disponível. Uma **estação de trabalho administrativa segura (SAW)** é um computador com uma superfície de ataque muito reduzida, executando o mínimo possível de aplicativos.

As contas de administrador tradicionais têm permissões permanentes. As permissões “just-in-time” (JIT) significam que os privilégios elevados de uma conta não são atribuídos no momento do login. Em vez disso, eles devem ser solicitados explicitamente e são concedidos apenas por um período limitado. Isso é denominado **zero standing privileges (ZSP)**.

Existem três modelos principais para sua implementação:

- **Elevação temporária:** significa que a conta ganha direitos administrativos por um período limitado. A funcionalidade “User Account Control” (UAC) (controle de conta do usuário) do Windows e o comando sudo no Linux usam esse conceito.
- **Cofre/corretagem de senhas:** significa que a conta privilegiada deve ser “retirada” de um repositório e fica disponível por um tempo limitado. O administrador deve registrar uma justificativa para usar os privilégios. A aprovação da solicitação pode ser automatizada por políticas aplicadas pelo sistema ou exigir intervenção manual, fornecendo uma medida de [[controle M de N]]. Isso oferece uma melhor supervisão das contas do que a elevação temporária e uma melhor proteção contra o comprometimento de credenciais privilegiadas.
- **Credenciais efêmeras:** significa que o sistema gera ou habilita uma conta para realizar a tarefa administrativa e, após a conclusão da tarefa, a destrói ou desativa. A participação temporária ou efêmera em grupos ou funções de segurança pode servir a um propósito similar.

Nota:

Além de administradores humanos, o PAM também se aplica a contas de serviço.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um dos recursos mais importantes de um sistema operacional é o *provedor de autenticação*, que é a arquitetura e o código de software que sustentam o mecanismo pelo qual o usuário é autenticado antes de iniciar um shell.

A autenticação baseada em conhecimento depende de hashes criptográficos. Uma senha de texto simples geralmente não é transmitida ou armazenada em um banco de dados de credenciais, devido ao risco de comprometimento. Em vez disso, a senha é armazenada como hash criptográfico. Quando o usuário insere uma senha para fazer login, um autenticador converte o que é digitado em um hash e transmite isso a uma autoridade. A autoridade compara o hash enviado com o do banco de dados e autentica a entidade somente se as senhas corresponderem.

Autenticação do Windows

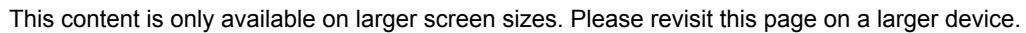
A autenticação do Windows envolve uma arquitetura complexa de componentes (docs.microsoft.com/en-us/windows-server/security/windows-authentication/credentials-processes-in-windows-authentication (<https://docs.microsoft.com/en-us/windows-server/security/windows-authentication/credentials-processes-in-windows-authentication>)), mas os três cenários a seguir são os mais comuns:

- **Autenticação local do Windows:** O Local Security Authority Subsystem Service (LSASS, Serviço de Subsistema da Autoridade de Segurança Local) compara a credencial enviada a um hash armazenado no banco de dados do Security Accounts Manager (SAM, Gerenciador de Contas de Segurança), que faz parte do registro do sistema. Esse processo também é chamado de *autenticação interativa* o "interactive logon".
- **Autenticação em rede do Windows:** O LSASS pode encaminhar as credenciais para autenticação a um controlador de domínio do Active Directory (AD, Diretório Ativo). O sistema preferencial para autenticação em rede é baseado no Kerberos, mas aplicativos de rede legados podem utilizar a [[autenticação NT LAN Manager (NTLM)]].
- **Autenticação remota:** Utilizada quando o dispositivo do usuário não está conectado diretamente à rede local. A autenticação pode ocorrer por meio de uma rede privada virtual (VPN), Wi-Fi corporativo ou portal web. Esses métodos utilizam protocolos para criar uma conexão segura entre a máquina cliente, o dispositivo de acesso remoto e o servidor de autenticação.

Autenticação do Linux

No Linux, os nomes das contas de usuários locais são armazenados em `/etc/passwd`. Quando um usuário faz login em um shell interativo local, a senha é verificada em relação ao hash armazenado em `/etc/shadow`. Geralmente, o login interativo em uma rede é realizado usando o Secure Shell (SSH). Com o SSH, o usuário pode ser autenticado usando chaves criptográficas, em vez de uma senha.

Um [[módulo de autenticação plugável (PAM)]] é um pacote que permite a integração de diferentes provedores de autenticação, como login por smart card. A estrutura PAM também pode ser usada para implementar a autenticação em serviços de diretório de rede.



Cada objeto no diretório tem uma série de atributos. O esquema de diretório descreve os tipos de atributos, as informações que eles contêm e se eles são opcionais ou necessários. Para que produtos de diferentes fornecedores sejam interoperáveis, a maioria dos serviços de diretório é baseada no [[Lightweight Directory Access Protocol (LDAP)], desenvolvido a partir de um padrão chamado X.500.

Em um diretório do tipo X.500, um `[[distinguished name (DN)]]` é um conjunto de atributos que define um identificador exclusivo para qualquer recurso. Um nome distinto é composto de pares de atributo-valor separados por vírgulas. O atributo mais específico é listado primeiro e os atributos sucessivos tornam-se progressivamente mais amplos. Esse atributo mais específico é o nome distinto relativo, pois identifica exclusivamente o objeto no contexto de valores de atributos sucessivos (pais).

[illegible]

Descrição

O menu no topo exibe: arquivo, ação, exibir e ajuda. Abaixo, um painel à esquerda mostra opções para o ADSI Edit, com a opção CN igual a users selecionada. A tabela central lista os nomes, classes e distinguished names. O nome, CN igual a bobby; classe, user; e distinguished name, CN igual a bobby, CN igual a users, DC igual a classroom, DC igual a local está selecionado. Um painel à direita intitulado ações lista as ações, CN igual a users e CN igual a bobby, cada uma seguida pela opção mais.

Alguns dos atributos comumente usados incluem common name (CN) (nome comum), organizational unit (OU) (unidade organizacional), organization (O) (organização), country (C) (país) e domain component (DC) (componente de domínio).

Por exemplo, o nome distinto de um servidor da Web operado pela Widget no Reino Unido pode ser o seguinte:

```
CN=WIDGETWEB, OU=Marketing, O=Widget, C=UK, DC=widget, DC=foo
```

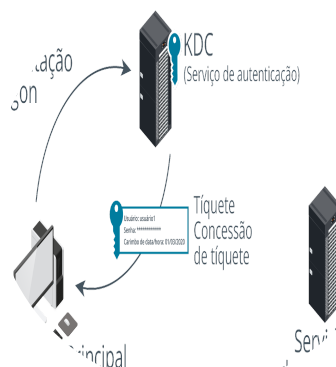


This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um sistema de [[single sign-on (SSO)]] permite que o usuário se autentique em um sistema e receba autorizações em servidores de aplicativos integrados, sem precisar inserir as credenciais novamente.

[[Kerberos]] é um protocolo de autenticação e autorização em rede do tipo single sign-on utilizado em muitas redes, principalmente na implementação do serviço Active Directory (AD) da Microsoft. O nome Kerberos é uma homenagem ao Cérbero, o cão de guarda de três cabeças de Hades, porque consiste em três partes. Os clientes solicitam serviços aos servidores de aplicação, ambos confiando em um intermediário — um centro de [[distribuição de chaves (KDC)]] — para atestar sua identidade. Dois serviços compõem um KDC: o serviço de autenticação e o serviço de concessão de tiquetes.

Figura 1. Serviço de autenticação do Kerberos.



Imagens © 123RF.com.

Descrição

O KDC (serviço de autenticação) envia o ticket-granting ticket (usuário, senha e carimbo de data/hora) para o principal, que gera uma solicitação de logon direcionada ao KDC. O servidor de aplicação verifica se a conta do usuário está presente.

O Kerberos pode autenticar usuários humanos e serviços de aplicativos. Esses são coletivamente chamados de *principais*. Por exemplo, para a autenticação de um domínio do Windows, a primeira etapa do SSO do Kerberos é autenticar com um servidor KDC, implementado como um controlador de domínio.

1. O principal envia ao serviço de autenticação (AS) uma solicitação de [[Ticket Granting Ticket (TGT).]]

Este é composto pela criptografia da data e hora no computador local, tendo como chave o hash da senha do usuário.

Nota:

O hash da senha em si não é transmitido pela rede. Embora nos referimos a senhas para simplificar, o sistema pode usar outros autenticadores, como login de smart card (cartão inteligente).

2. O AS verifica se a conta de usuário está presente, se pode decodificar a solicitação combinando o hash de senha do usuário com o do banco de dados do Active Directory e se a solicitação não expirou.

Se a solicitação for válida, o AS responderá com os seguintes dados:

- **Ticket Granting Ticket (TGT):** contém informações sobre o cliente (nome e endereço IP), além de um carimbo de data/hora e período de validade. Isso é criptografado usando a chave secreta do KDC.
- **Chave de sessão de TGS:** comunica-se entre o cliente e o Ticket Granting Service (TGS) (serviço de concessão de tíquetes). Esta é criptografada usando um hash da senha do usuário.

O TGT é um exemplo de token lógico. Tudo o que o TGT faz é identificar quem você é e confirmar que a sua sessão foi autenticada; ele não fornece acesso a nenhum recurso de domínio.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Supondo que o usuário tenha digitado a senha correta, o cliente pode descriptografar a chave de sessão do Ticket Granting Service (TGS) (serviço de concessão de tíquetes), mas não o TGT. Isso estabelece que o cliente e o KDC (Kerberos Key Distribution Center) conhecem o mesmo segredo compartilhado e que o cliente não pode interferir no

TGT.

1. Para acessar recursos no domínio, o principal solicita um tíquete de serviço (um token que concede acesso a um servidor de aplicativo de destino).

Este processo de concessão de tíquetes de serviço é tratado pelo TGS.

2. O principal envia ao TGS uma cópia do seu TGT e o nome do servidor de aplicativos que deseja acessar, além de um autenticador, que consiste em um ID de cliente com carimbo de data/hora criptografado usando a chave de sessão do TGS.

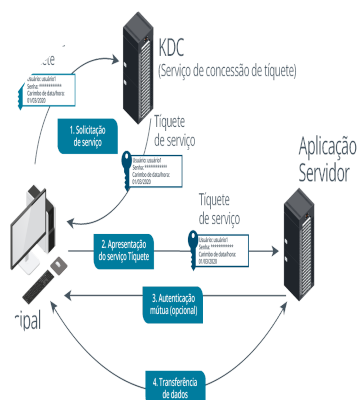
O TGS deve ser capaz de descriptografar ambas as mensagens usando a chave secreta do KDC para a primeira e a chave de sessão do TGS para a segunda. Isso confirma que o pedido é genuíno. Também verifica se o tíquete não expirou e se não foi usado antes (constituindo assim um replay attack).

3. O serviço TGS responde com o seguinte:

- o Uma **chave de sessão de serviço** — usada entre o cliente e o servidor do aplicativo. Ela é criptografada com a chave de sessão TGS.
- o Um **tíquete de serviço** — contém informações sobre o principal, como um registro de data/hora, endereço IP do sistema, Security Identifier (SID) (identificador de segurança) e os SIDs dos grupos aos quais ele pertence e a chave de sessão do serviço. Ele é criptografado usando a chave secreta do servidor de aplicativos.

4. O principal encaminha o tíquete de serviço, que não consegue descriptografar, ao servidor de aplicativos e adiciona outro autenticador com carimbo de data/hora, que é criptografado usando a chave de sessão do serviço.

Figura 1. Serviço de concessão de tíquetes do Kerberos



Imagens © 123RF.com.

Descrição

As etapas são as seguintes: 1. O principal envia uma solicitação de serviço (ticket granting ticket com usuário, senha e carimbo de data/hora) para o KDC (serviço de concessão de tickets). O KDC envia o ticket de serviço (usuário, senha e carimbo de data/hora) para o principal. 2. O principal apresenta o ticket de serviço (usuário,

- senha e carimbo de data/hora) ao servidor de aplicação. 3. O servidor de aplicação envia autenticação mútua (opcional) ao principal. 4. Ocorre a transferência de dados entre o principal e o servidor de aplicação.
5. O servidor de aplicativos descriptografa o tíquete de serviço para obter a chave de sessão do serviço usando sua chave secreta, confirmando que o principal enviou uma mensagem não adulterada. Em seguida, ele descriptografa o autenticador usando a chave de sessão do serviço.
6. Opcionalmente, o servidor de aplicativos responde ao principal com o registro de data/hora usado no autenticador, que é criptografado usando a chave de sessão do serviço. O principal descriptografa o registro de data/hora e verifica se ele corresponde ao valor já enviado e conclui que o servidor de aplicativos é confiável.
- Isso significa que o servidor está autenticado ao principal (denominado de *autenticação mútua*). Assim, evita-se um ataque on-path, no qual um usuário mal-intencionado pode interceptar as comunicações entre o principal e o servidor.
7. O servidor agora responde às solicitações de acesso (supondo que elas estejam em conformidade com a lista de controle de acesso do servidor).

Uma das desvantagens do Kerberos é que o KDC representa um ponto único de falha para a rede. Na prática, os servidores de backup do KDC podem ser implementados (por exemplo, o Active Directory oferece suporte a vários controladores de domínio, cada qual executando o serviço do KDC).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Federação]] é a ideia de que uma rede precisa ser acessível para além de um grupo bem definido de colaboradores. Uma empresa pode precisar tornar partes de sua rede abertas a parceiros, fornecedores e clientes. Empresas podem gerenciar suas contas de funcionários facilmente, mas gerenciar contas para cada fornecedor ou cliente internamente pode ser bastante mais difícil. Federação significa que a empresa confia em contas criadas e gerenciadas por uma rede diferente. Um outro exemplo seria um usuário do Google Workspace e do Twitter. Se o Google e o Twitter estabelecerem uma rede federada para fins de autenticação e autorização, o usuário poderá fazer login no Twitter usando suas credenciais do Google, e vice-versa.

Uma rede local pode usar tecnologias como LDAP e Kerberos, que são frequentemente implementadas como uma rede do Windows Active Directory, porque, assim, a administração de contas e dispositivos pode ser centralizada. Ao implementar a federação, a forma como a autenticação e a autorização são elaboradas vem com mais restrições e requisitos adicionais para garantir a interoperabilidade entre diferentes plataformas. Os aplicativos da Web podem ser

incompatíveis com o Kerberos, enquanto as redes de terceiros podem ser incompatíveis com a federação direta com o Active Directory/LDAP. O design dessas redes na nuvem provavelmente requer o uso de outros protocolos ou estruturas padrão para interoperabilidade entre aplicativos da Web.

Esses protocolos de federação interoperáveis usam Claims-based Identity (identidade baseada em declarações). Embora a implementação técnica e a terminologia sejam diferentes, o modelo geral é semelhante ao do SSO do Kerberos:

1. O principal tenta acessar um Service Provider (SP) (provedor de serviços).

O provedor de serviço redireciona o principal para um [[provedor de identidade (IdP)]] para autenticação.

2. O principal se autentica com o provedor de identidade e obtém uma declaração na forma de algum tipo de token ou documento assinado pelo IdP.
3. A entidade principal apresenta a declaração ao provedor de serviços.

O provedor de serviços consegue validar se o IdP assinou a declaração devido à sua relação de confiança com o IdP.

4. O provedor de serviços agora pode conectar a entidade principal autenticada ao seu próprio banco de dados de contas para determinar suas permissões e outros atributos.

Ele pode ser capaz de consultar atributos do perfil de conta de usuário mantido pelo IdP, caso a entidade tenha autorizado esse tipo de acesso.

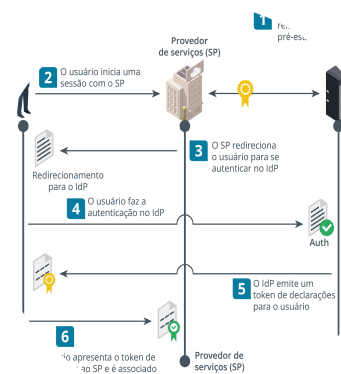


Figura 1. Visão geral da gestão de identidade federada.

Imagens © 123RF.com.

Descrição

Os 6 passos são os seguintes: 1.O provedor de serviço (SP) e o provedor de identidade (IdP) possuem uma relação de confiança pré-estabelecida. 2.O usuário inicia uma sessão com o SP. 3.O SP redireciona o usuário para o IdP para autenticação. 4.O usuário se autentica no IdP. 5.O IdP emite um token de reivindicações para o usuário. 6.O usuário apresenta o token de reivindicações ao SP e é associado a uma conta legítima e a um conjunto de autorizações.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Uma rede ou nuvem federada precisa de protocolos e tecnologias específicos para implementar afirmações de identidade do usuário e transmitir atestados entre o principal, a parte confiante e o provedor de identidade. A [[Security Assertion Markup Language (SAML) (Linguagem de marcação de afirmação de segurança)]] é uma dessas soluções. As afirmações da SAML são escritas em eXtensible Markup Language (XML) (linguagem de marcação extensiva). As comunicações são estabelecidas usando HTTP/HTTPS e o [[Simple Object Access Protocol (Protocolo Simples de Acesso a Objetos) (SOAP)]] . Os tokens seguros são assinados usando a especificação de assinatura XML. O uso de uma assinatura digital possibilita que a parte confiável confie no provedor de identidade.

Um exemplo de uma implementação SAML é a Amazon Web Services (AWS), que funciona como um provedor de serviços SAML. Isso permite que as empresas que usam a AWS desenvolvam aplicativos em nuvem para gerenciar as identidades dos usuários de seus clientes e fornecer permissões na AWS sem precisar criar contas diretamente na plataforma.

```
<samlp:Response xmlns:samlp="urn:oasis:names:tc:SAML:2.0:protocol"

xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion" ID="200" Version="2.0"

IssueInstant="2020-01-01T20:00:10Z " Destination="https://sp.foo/saml/acs"
InResponseTo="100".

<saml:Issuer>https://idp.foo/sso</saml:Issuer>

<ds:Signature>...</ds:Signature>

<samlp:Status>... (success) ...</samlp:Status.

<saml:Assertion xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"

xmlns:xs="http://www.w3.org/2001/XMLSchema" ID="2000" Version="2.0"

IssueInstant="2020-01-01T20:00:09Z">

<saml:Issuer>https://idp.foo/sso</saml:Issuer>

<ds:Signature>...</ds:Signature>
```

```
<saml:Subject>...

<saml:Conditions>...

<saml:AudienceRestriction>...

<saml:AuthnStatement>...

<saml:AttributeStatement>

  <saml:Attribute>...

  <saml:Attribute>...

  <saml:AuthnStatement>...

</saml:Assertion>

</samlp:Response>
```



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Muitas nuvens públicas utilizam interfaces de programação de aplicativos (APIs) baseadas em [\[\[Representational State Transfer \(REST\)\]\]](#), em vez de SOAP. Elas são chamadas de APIs RESTful. Nos aspectos em que o SOAP é um protocolo bem especificado, o REST é uma estrutura arquitetônica mais livre. Isso permite que o provedor de serviços tenha mais opções sobre os elementos de implementação. Em comparação com o SOAP e o SAML, há um suporte melhor para aplicativos móveis.

A autenticação e a autorização para uma API RESTful são frequentemente implementadas utilizando o protocolo [\[\[Open Authorization \(OAuth\)\]\]](#). O OAuth foi desenvolvido para facilitar o compartilhamento de informações (recursos) dentro de um perfil de usuário entre sites. O usuário cria uma conta protegida por senha em um provedor de identidade (IdP). O usuário pode vincular essa identidade a um site de consumidor OAuth sem fornecer a senha a esse site. Um usuário (proprietário do recurso) pode conceder a um cliente OAuth autorização para acessar alguma parte da sua conta. Neste contexto, um cliente é um aplicativo ou site de consumidor.

A conta de usuário é hospedada por um ou mais servidores de recursos. Um servidor de recursos é chamado de servidor de API porque hospeda as funções que permitem que os clientes OAuth (sites de consumidor e aplicativos móveis) acessem os atributos do usuário. Um servidor de autorização processa solicitações de autorização. Um único

servidor de autorização pode gerenciar vários servidores de recursos; da mesma forma, o servidor do recurso e o da autorização podem ser a mesma instância de servidor.

O aplicativo ou serviço do cliente deve ser registrado no servidor de autorização. Como parte desse processo, o cliente registra um URL de redirecionamento, que é o endpoint que processará os tokens de autorização. O registro também fornece ao cliente uma identificação e um segredo. A identificação pode ser exposta publicamente, mas o segredo deve ser mantido em sigilo entre o cliente e o servidor de autorização. Quando o aplicativo cliente solicita a autorização, o usuário aprova que o servidor de autorização conceda a solicitação usando um método apropriado. O OAuth suporta vários tipos de concessão (ou fluxos) para uso em diferentes contextos, como de servidor a servidor ou de aplicativo móvel a servidor. Dependendo do tipo de fluxo, o cliente obterá um token de acesso validado pelo servidor de autorização. O cliente apresenta o token de acesso ao servidor de recursos, que aceita a solicitação do recurso se o token for válido.

O OAuth utiliza o formato [[JavaScript Object Notation (JSON)]] Web Token (JWT) para os dados de reivindicações. Os JWTs podem ser passados como strings codificadas em Base64 em URLs e cabeçalhos HTTP e podem ser assinados digitalmente para fornecer autenticação e integridade.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Você já deve ser capaz de avaliar o design e o uso de produtos de autenticação para atender aos requisitos de confidencialidade, integridade e disponibilidade. Com um guia de configuração específico do produto, você deve ser capaz de implementar protocolos e tecnologias como MFA, autenticação sem senha, SSO do Kerberos e gestão de identidade federada.

Diretrizes para implementar o gerenciamento de identidade e acesso

Siga as seguintes diretrizes ao implementar controles de autenticação:

- Avalie os requisitos de design quanto a confidencialidade, integridade e disponibilidade, considerando o contexto da solução de autenticação (rede privada, Web pública, gateway de VPN ou instalações físicas do site, por exemplo).
- Determine se a autenticação multifator (MFA) ou a autenticação sem senha são necessárias e quais tokens de hardware ou tecnologias biométricas atenderiam ao requisito:
 - Os fatores de propriedade incluem smart cards, chaves OTP/FOBS, chaves de segurança e aplicativos autenticadores OTP instalados em um dispositivo confiável.

- o As tecnologias biométricas incluem impressão digital e facial com eficácia determinada por métricas como FAR, FRR, CER, velocidade e acessibilidade.
 - o A verificação em duas etapas pode fornecer um token adicional para um dispositivo ou conta confiável por SMS, telefone, email ou notificação push.
 - o Os gerenciadores de senhas podem fornecer melhor segurança para a autenticação por senha.
- Estabeleça requisitos para controle de acesso entre modelos discricionários, obrigatórios, baseados em função e em atributos e se o escopo deve incluir serviços federados (por exemplo, no local e na nuvem).
- Configure contas/funções e recursos com as configurações de permissões apropriadas usando o princípio do privilégio mínimo.
- Configure as políticas da conta para proteger a integridade:
 - o Políticas de credenciais para garantir a proteção de contas padrão e privilegiadas, incluindo a seleção segura de senhas.
 - o Políticas da conta para aplicar acesso condicional com base na localização e no horário.
- Estabeleça procedimentos de provisionamento para emitir identidades digitais e credenciais de contas com segurança.
- Estabeleça procedimentos de desprovisionamento para remover privilégios de acesso quando funcionários ou contratados deixarem a empresa.
- Implemente SAML ou OAuth para facilitar o login único entre redes locais e serviços/aplicativos na nuvem.



This content is only available on larger screen sizes. Please revisit this page on a larger device.